

Data Protection Impact Assessment

Data Forms reconciliation: verifying call answers against submitted applications

ASSESSMENT COVERS	The CallGuard AI Data Forms module, specifically the reconciliation feature that compares what a customer said on a recorded call against the application submitted to an insurer, and the change to transcript redaction that makes it possible.
PREPARED BY	CallGuard AI (processor)
CONTROLLER	Trust Point (first deploying firm)
VERSION	0.6, draft for controller review
DATE	15 September 2026
STATUS	DRAFT. Not signed. The processing described here must not be enabled in production until this assessment is completed and signed by the controller.
REVIEW DUE	12 months from sign-off, or on any material change to the processing

Change log

- **0.6** — A gap this assessment had not described, closed and disclosed together (new **section 4.12**). Learning how to read a new insurer's application format — a one-off call to Claude, separate from reconciliation's own per-sale extraction — was sending up to roughly 12,000 characters of the raw, unredacted document: name, date of birth, address, policy number and health disclosures included. Nothing in versions 0.1–0.5 said this call existed. It now sends the same document with every field's value replaced by a typed placeholder, keeping only the labels, delimiters and section markers the model actually needs. New **action 14** asks the controller and CallGuard to establish together whether any real document reached Anthropic unredacted this way before the fix.
 - **0.5** — One new disclosure, and one new open decision, both in **section 4.11**. The tokenised page an adviser opens from their feedback email — no login, the URL is the credential — used to show that adviser's own name and a count of findings. It now names each finding and carries the firm's own remediation guidance for it, because the same page has been given the job of collecting what the adviser did about each one. Assessed as acceptable: the recipient is the named adviser, the content is an assessment of their own conduct, the guidance was written by the firm against a checkpoint rather than derived from any call, and the page still names no customer and links to no sale. The model's **reasoning** is **not** included, on the same test that keeps it out of the email for firms holding health in the clear — new **action 13** puts that question to the controller rather than answering it in a build.
 - **0.4** — Action 8 closes. The control R5 was conditional on now exists and is covered by test (new section 4.10). It is worth recording plainly that when this control was built the field it governs was **already leaving**: a breach's **evidence** is a verbatim quote from the call, and it was travelling ungated to the tenant's CRM, to outbound webhooks including the live-session events, to two CSV downloads, and to the partner pull endpoint. Nothing in this document had ever said it was safe to send; the control simply had not been built, and 0.3 listed action 8 as open. The controller should treat the question of what has already reached those destinations as a separate matter from the control now being in place — see 4.10. Section 4.10 also records the one place the quote is still exported deliberately, the claims-defence pack, which was previously an implicit carve-out and is now a written one.
 - **0.3** — Two of the three open risks close, and both remaining CallGuard preconditions are met. The control R7 was conditional on now exists: an in-house bank-detail redaction running on every transcript before it is stored or sent anywhere (new section 4.9), verified end to end on a real call with every category permitted (action 12). The controller has decided action 11: unredacted transcripts are restricted to the **admin** role, stricter than the 0.1 design, and that restriction is implemented and enforced at the API. Actions 10, 11 and 12 are closed; the outstanding items are the controller's own (1–6) plus CallGuard's 7–9.
 - **0.2** — Replaces the two-tier transcript design of 0.1 with a single unredacted transcript, and the all-or-nothing exemption with per-category permissions. **Residual risk is higher than in 0.1**; see sections 4.7 and 11. Adds the empirical finding that redaction was degrading the compliance analysis (3.4), the application pack as a data category (5), and the payment-data trade-off as a new risk (R7).
 - **0.1** — Initial draft, two-tier transcript with 12 month retention on the unredacted tier.
-

1. Why this assessment is required

A DPIA is mandatory under UK GDPR Article 35(3) where processing involves special category data on a large scale, or systematic monitoring. This processing meets both descriptions:

- It processes **health data** (Article 9(1) special category), namely the health and lifestyle disclosures a customer makes when applying for protection insurance.
- It applies **systematically to every call**, monitoring adviser conduct across all recorded calls for the deploying firm.

It is also a material change from CallGuard's existing processing. Until now, CallGuard has never stored the content of a health disclosure: health, personal identifiers, dates of birth, addresses and payment data were redacted by the transcription provider before any CallGuard system received them, leaving only typed placeholders such as [CONDITION_7] . This feature requires that health and identity answers are retained in readable form. That is a genuine increase in risk and is the reason for this assessment.

2. Roles

PARTY	ROLE	BASIS
Trust Point	Controller	Determines the purpose (verifying its own advisers' applications), decides which questions are captured, owns the customer relationship and the privacy notice.
CallGuard AI	Processor	Processes only on the controller's documented instructions, under the data processing terms in the service agreement.
Deepgram	Sub-processor	Speech to text transcription.
Anthropic	Sub-processor	Language model extraction and comparison.

The controller is responsible for the lawful basis, the privacy notice, and responding to data subject rights requests. CallGuard is responsible for the technical and organisational measures in section 8.

3. What the processing does and why

3.1 The problem being solved

When a customer applies for protection insurance, the adviser asks a set of health and lifestyle questions defined by the insurer and keys the answers into the insurer's portal. If a disclosure the customer made on the call does not reach the application, the policy can be voided at claim stage. The customer, who believes they disclosed correctly, loses cover at the point of greatest need. The firm carries the regulatory and reputational consequence.

Today this is detected only reactively, if at all, usually when a claim is declined years later.

3.2 What the feature does

For each sale:

1. The submitted application is retrieved from the firm's CRM and the questions and answers are extracted from it.
2. The recorded call or calls for that sale are analysed to establish, for each question: whether the adviser asked it, whether the customer answered, and what the customer's answer was.
3. The two are compared, and three categories of discrepancy are flagged:
 - a required question that was never asked;
 - an answer the customer gave that does not appear in the application;
 - an application entry that does not match what the customer said.
4. Flags are surfaced to supervisors in CallGuard and delivered by the existing alert channels, so a discrepancy can be corrected while the application is still amendable. **Flags are not pushed into the firm's CRM**, a deliberate decision that keeps this data inside one system.

The output is also usable defensively: if an insurer later queries what a customer disclosed, the firm can produce the question, the answer, and the point in the recording where it was given.

3.3 Why the answers must be retained in readable form

Two of the three discrepancy types turn only on whether a question was asked and whether an answer exists. The third does not: establishing that an application says one thing and the customer said another requires both values, and requires the flag to state both so a supervisor can act. A flag reading only "mismatch on question 7" is not actionable and does not meet the purpose.

3.4 Why redaction cannot simply be left in place (empirical finding)

This is the finding that drove the design change in 0.2, and it is recorded here because it bears directly on necessity.

An examination of 63 transcribed calls for the deploying firm found that the transcription provider's health redaction removes not just the customer's answer but **the subject of the question**. Across all 63 calls, the terms *diabetes*, *cancer*, *stroke*, *asthma*, *depression* and *anxiety* appeared **zero times**. They had been

replaced with untyped placeholders. A representative extract:

"Any other medication apart from, obviously, the [CONDITION_7] Are you on medication for your [CONDITION_12] ... just your [DRUG_6] so far? ... And blood pressure, cholesterol, [CONDITION_13] all up to date?"

Three consequences follow:

- 1. It is **not possible to establish that a question was asked** for the cancer, diabetes, stroke, respiratory or mental-health sections, because the words that identify those questions are gone. A detector relying on the redacted transcript would report every one of them as "never asked" on every sale, an allegation against an adviser that is false by construction.
- 2. Redaction also **corrupts** rather than merely removing. One transcript reads "She said stent [MONEY_25] ", a number misclassified as currency.
- 3. The same degraded transcripts are already being read by the existing compliance scoring the firm pays for. Redaction is therefore not a neutral safeguard; it has a cost to the accuracy of the service.

The purpose cannot be achieved on redacted transcripts. That is a finding from the data, not an assumption.

4. The processing design, and the measures built into it

4.1 A single transcript, with per-category permissions

Version 0.1 proposed two transcripts: a redacted one for everyday use and a separate unredacted one for reconciliation. That is replaced by a **single transcript**, with redaction configured per organisation as an explicit list of categories that may be kept in the clear. Anything not listed stays redacted.

This is a genuine simplification (one transcription pass, one stored transcript, no duplicate record to secure, retain and purge separately) but it is also **less protective than 0.1**, and section 4.7 records that honestly.

4.2 Two profiles, two different legal bars

Separating the categories matters because they are not equivalent:

PROFILE	CATEGORIES KEPT IN THE CLEAR	LEGAL BASIS NEEDED
None (default)	—	n/a
Identity	name, date of birth, address, email	Article 6 only
Full	the above plus health (phi)	Article 9. This assessment.

The distinction is practical, not theoretical. Some insurers return a summary of key facts containing **no health questions at all** — one examined product records only name, address, date of birth, occupation, employment status, residency, cover options and premium. Reconciling those needs the identity profile and nothing more. Under 0.1's single switch, such a firm would have had to store every health disclosure in the clear to check a date of birth, which fails data minimisation. Under 0.2 it does not.

4.3 Payment data is excluded structurally, not by convention

Card numbers, sort codes and account numbers remain redacted for every organisation with no configuration path to change it. This is enforced in **two independent places**: a **CHECK** constraint in the database that makes the payment category impossible to record as permitted, and a filter in the transcription service that removes it regardless of what the configuration says. Unit tests cover the second. Neither a bad configuration write nor a bug in the service alone can expose payment data.

This keeps card data out of CallGuard entirely and the platform outside PCI DSS scope.

4.4 Enablement is controlled and audited

Redaction categories cannot be changed by a firm's own administrators. They are set per firm by CallGuard platform staff, require a recorded justification naming this assessment and its approver, and every change is written to the append-only audit log. No firm is enabled without a signed assessment.

4.5 The application pack is read, not retained

The document the firm receives from the insurer is a pack, not a single form. One examined example ran to 29 pages: a covering letter, the 16 page application form, a medical-consent form, a blank confirmation form, the underwriting quote, and the firm's own commission schedule.

Only the application form section is read. The pack is retrieved, the question and answer pairs are extracted, and the pack itself is **discarded rather than stored**. CallGuard therefore holds no copy of the medical-consent form, the underwriting decision, or the commission schedule, none of which are relevant to the purpose. The pack remains in the firm's CRM, its system of record.

This extraction is deterministic code, not a model, and it runs on every sale. Teaching CallGuard how to extract from a *new* insurer format — once per format, not once per sale — is a different, model-involving step. See 4.12.

4.6 Scope of questions

Only the questions the controller defines are captured. The controller can mark any question as confirm-only, in which case the answer content is never retained and only "asked" and "answered" are recorded.

4.7 What 0.1 protected that 0.2 does not

Recorded plainly, because a DPIA that hides a regression is worthless:

SAFEGUARD IN 0.1	STATUS IN 0.2
Health data only on sales entering reconciliation	Gone. Every call for an enabled firm.
12 month retention on the unredacted record	Gone. Health now persists for the firm's standard retention period (5 year default).
Supervisor and administrator access only	Restored, and narrowed. The controller has restricted unredacted transcripts to the <code>admin</code> role alone — stricter than 0.1, which included supervisors. See R3 and action 11.
Regeneration from audio instead of retention	Gone. There is no separate record to expire.

4.8 Alternatives considered

OPTION	WHY NOT CHOSEN
Keep redaction, presence-only checks	Cannot deliver the value-mismatch flag, which is the core of what the controller requires. Section 3.4 shows it cannot reliably deliver the "never asked" flag either.
Store only a match/mismatch verdict, discard values	A flag that cannot state what the customer said against what was submitted is not actionable by a supervisor.
Two-tier transcript (version 0.1)	Deliverable and more protective, but requires a second transcription pass per sale and a duplicate record with its own access model and retention clock. Rejected on cost and complexity. This remains the fallback if residual risk is judged unacceptable.
Per-question redaction	Not technically available. The provider redacts the whole transcript at source, before any concept of "which question is this" exists.

4.9 Bank details are removed by a control CallGuard operates (*new in 0.3*)

Version 0.2 recorded, in R7, that the provider's number-sequence category was the thing actually catching bank details spoken aloud, and that permitting it must not happen until CallGuard operated its own control for that specific data. That control now exists.

What it does. Every transcript passes through a bank-detail redaction before it is stored, before the transcript-cleanup pass, and therefore before it reaches either sub-processor or any export. It anchors on the spoken phrase — "sort code", "account number", "bank account" — and removes the digits dictated in the passage that follows, replacing them with `[SORT_CODE]` or `[ACCOUNT_NUMBER]`. It runs on every transcript regardless of the firm's category configuration, so a configuration change cannot switch it off.

Why it is anchored on the phrase rather than the number. A six digit sequence is indistinguishable from a policy value or a reading. The phrase preceding it is not. This is what allows weight, height, age, units of alcohol and blood pressure to survive while the bank details do not, which is the requirement 0.2 could not

meet in both directions at once.

Two properties worth stating. The digits are also removed from the raw provider payload, not only the readable transcript, because that payload holds every word individually and would otherwise retain what the transcript hides. And the provider's payment-data category remains force-enabled underneath this control; this is a second layer for what that category demonstrably misses, never a replacement for it (see 4.3).

Measured, not asserted. Validated against 71 real transcripts from the first deploying firm, 34 of which discuss bank details across 172 separate passages:

CHECK	RESULT
Bank details surviving, tested on the firm's real dialogue with digits reinstated	0 of 30 reconstructed cases
Numeric health and policy answers destroyed	0 of 424
Existing stored transcripts altered	0 of 71
Live end-to-end run — a real 20 minute sale re-transcribed with every category permitted, bank-length digit runs surviving (<i>action 12, 3 August 2026</i>)	0

The middle row is the one that makes the feature viable, and the first is the one that makes it permissible. The last is action 12, and it is the only one measured against live provider output rather than against reconstructed text.

That run also confirmed the finding in 3.4 from the other direction. Fifteen redaction tag types disappeared, including those for conditions, medication, dose and age, and phrases the compliance scoring depends on — the regulator's name, the firm's own name, "regulated by" — became visible where redaction had been removing them. Email addresses and dates of birth appeared in the clear as well, which is the permitted configuration behaving as specified rather than a fault, and is what "every category permitted" looks like in practice.

A limitation of the check itself, recorded rather than glossed. The automated leak check looks for runs of digits. It found none of five digits or more, but it cannot see a number spoken as words, so it can neither confirm nor deny that case. That is the same residual already stated in R7 and it is a property of the check, not evidence about the control.

What this does not close. The control depends on someone saying the phrase. A customer who volunteers account digits with no such phrase anywhere in the preceding passage would not be caught by the anchored pass. Across all 34 real calls examined every disclosure was preceded by an anchor, because the adviser has to ask before the customer answers, so the likelihood is low rather than absent. Three things bound it: the payment-data category still runs at source; any single word in the raw payload that is a run of six or more digits is removed outright regardless of context; and the verification script fails a run if a bank-length run survives anywhere in a transcript, which is action 12 and is to be run against real calls under the proposed category list before enablement.

4.10 Quotes from the call do not leave the platform (new in 0.4)

R5 required that exports and notifications carry the question, the fact of a discrepancy and a link back into CallGuard, never the answer content, and rated its residual **conditional on that control being implemented and covered by test** (action 8). This section records the control, and is written to be checked rather than believed.

What is governed. A compliance finding carries an `evidence` field. It is not a summary: the scoring instruction asks the model for "a direct quote from the transcript", so on a firm keeping health in the clear that field holds the customer's disclosure in their own words. It is a more exposing artefact than the model's `reasoning`, which is already withheld from the adviser feedback email for these firms. The reconciliation record's `call_answer` and `evidence` are the same kind of thing from the same source.

Where it was going. All of these were carrying the quote with no gate:

DESTINATION	WHAT IT WROTE
The firm's CRM — breach task	The finding, then the quote
The firm's CRM — QA record notes	The finding, then the quote
Outbound webhooks, batch scoring	The quote in the event body
Outbound webhooks, live sessions	The same, on a separate code path
Breaches CSV download	The quote and the model's reasoning, as columns
Data Forms CSV download	The quote, beside an answer cell that was already redacted
Partner pull endpoint	The quote and the reasoning, on the same API key as the webhook

What now happens. The quote is removed at each point of exit rather than at the point the payload is assembled, so a path added later inherits the control instead of having to remember it. The copy kept for delivery retry is the removed one, and the retry re-applies the filter in any case, so a delivery queued before this shipped cannot replay a quote. What still travels is the checkpoint, its severity, and the link — R5's prescribed shape. Where anything was removed the payload says so, in words on the CRM surfaces and as a field for machine consumers, so a shortened list cannot be mistaken for a call with nothing to quote. Where a finding never had a quote nothing is claimed.

Two gates, and the difference is the destination. For the firm's own CRM the test is whether the firm keeps **health** in the clear: the CRM is the firm's customer record and already holds the name and address, so withholding a quote there because it might contain a name would protect nothing. For every other destination — a webhook endpoint, a downloaded file, an API key's holder — the test is whether the firm keeps **any** category in the clear, because none of those is a system this assessment can say anything about.

Where a quote still leaves, deliberately. The claims-defence pack (`GET /journeys/:id/claims-defence`) exports the quote and the reconciliation answers, and continues to. It is the artefact produced when an insurer declines a claim or a customer complains, and what the customer disclosed is its subject matter; a pack without it would not do the job it exists for. It is org-scoped, restricted to admin, supervisor and viewer, and generated per sale on request rather than pushed anywhere. **This was previously an implicit exception**

and is now a stated one, so that closing action 8 does not read as a claim that no quote ever leaves. The controller should note it as the one route where a readable health disclosure is exported by design, under their own decision to send such a pack.

The reconciliation panel is unchanged, and R3's operational-consequence paragraph already contemplates it: a supervisor working a finding sees the flag, the question, the application answer and the evidence quote inside the platform. That is in-platform, not an export, and nothing here narrows it.

What this control does not tell you. It stops the quote leaving from now on. It says nothing about what already reached those destinations before it existed, which is a question of fact to be established from the delivery records and is for the controller and CallGuard to settle together, not for this section to assert either way.

4.11 The adviser's confirmation page now names the findings (*new in 0.5*)

Recorded here because it is a deliberate widening of a disclosure, it is **not** covered by the R5 control above, and it should be a decision rather than something the controller discovers.

What changed. The link in the adviser feedback email opens a page that requires no login — the token in the URL is the credential, because a large share of advisers have no account and this firm's have none. Until now that page showed the recipient's own name and a count of findings, and nothing else. It now lists each finding by name, the firm's own remediation guidance for it, and collects what the adviser did about it. The reason is that the page has been given a job it cannot do while anonymous: an adviser cannot honestly confirm they have seen feedback that is not shown to them, and cannot record an outcome against a finding it will not name.

Why this is assessed as acceptable. The recipient is the named adviser who handled the sale, reached at an address the firm holds for them. The content is an assessment of **their own conduct**, not the customer's data: a checkpoint label the firm wrote, and guidance the firm authored in advance against that checkpoint without seeing any customer. The page names no customer, states no client name, shows no score, links to no sale, and carries no transcript.

What is still withheld, and this is the part to check. On a firm that keeps health unredacted — this firm — the model's **reasoning** is already kept out of the feedback email, because it is derived from the call and can carry a health disclosure in the clear. **The same test is applied to this page**, which is unauthenticated and therefore no safer a destination than the email: where reasoning was withheld from the email it is withheld here, the page says so, and it points the adviser to their supervisor. The evidence quote governed by 4.10 has never been on this page and is not added to it.

The open question this creates. The design argues the opposite: that because this page is inside CallGuard and reachable without an account, it is precisely where the withheld detail *should* land, and that a no-login adviser currently being told "the detail is in CallGuard" is being pointed at nothing. That may well be right, and it would close a real gap. It is a controller decision about disclosing health-derived text to an unauthenticated URL, not an engineering one, so it has been left unbuilt and recorded as action 13. Relaxing it is one condition in one function.

4.12 Document text used to learn a new insurer format is redacted before it reaches the model (*new in 0.6*)

What this call is, and why it exists. Reconciliation reads a submitted application deterministically, using a stored profile that says where the questions, answers and section boundaries sit in that specific insurer's document (4.5). The profile has to be produced once, the first time a format is seen and again if the insurer changes their question set: the document's text is shown to Claude, which is asked to describe the document's *shape* — its delimiters, section markers and field labels — and nothing else. It is not asked to read or repeat any answer, and the config it returns is verified by actually parsing the real document with it before it is ever stored (see the note added to 4.5, and 3.2). This is a separate, occasional call, not the per-sale extraction that runs on every application.

Where the gap was. Until this fix, that call was given up to roughly 12,000 characters of the raw document exactly as extracted from the pack described in 4.5 — before any redaction. For a fully underwritten product that is the customer's name, date of birth, home address, policy number and their health and lifestyle disclosures, sent to Anthropic with nothing masked. This was the same category of data reconciliation already retains and this assessment already covers (section 5), reaching the same sub-processor the controller has already accepted for scoring (section 2) — but this specific flow was never described here, and it should have been. Nothing about it was logged (the application log on this path records only a file name, never document content), and the text itself is never stored; it exists only for the duration of the one model call. Neither of those facts is a reason it should have gone unredacted, only a bound on how far a gap that should not have existed reached.

What now happens. The document is redacted before this call is made. Redaction here is not selective by category the way transcript redaction is (4.1): every field's *value* is replaced with a typed placeholder — `[NAME]`, `[DOB]`, `[LOCATION_ADDRESS]`, `[POLICY_NUMBER]`, or `[VALUE]` for a free-text answer, health disclosures included — while the labels, question wording, delimiters and section markers are left untouched, because those are the only things the model's task requires it to read. It runs unconditionally, the same way for every firm, regardless of a tenant's transcript category configuration, because this call has never needed a real value to describe a document's shape.

What this does not change. The per-sale extraction that produces the reconciliation record itself (5, 4.5) is unaffected — it runs on the real, unredacted document using the profile this (now-redacted) call proposed, exactly as before. This section concerns only the one-off call that infers *how* to read a format, not the ongoing reading of it.

5. Data categories

CATEGORY	EXAMPLES	RETAINED	ARTICLE 9?
Health and lifestyle disclosures	Conditions, medication, smoking status, alcohol consumption, height and weight, family history	Transcript + reconciliation record	Yes
Identity data	Name, date of birth, address	Transcript + reconciliation record	No
Contact data	Telephone number, email address	Transcript. The telephone number is already held in the clear on every call record for call matching (1,624 of 1,626 for the first firm), so a number spoken in a transcript is not a new category of data.	No
Application content	Answers extracted from the insurer document	Reconciliation record	Yes , where health related
The insurer application pack	Multi-document pack from the CRM	Not retained. See 4.5.	Yes
Call recording	Audio	Existing processing, unchanged	Contains Article 9 content
Adviser conduct data	Which questions were asked or skipped, discrepancy flags	Reconciliation record	No
Payment data	Card and bank details	Excluded structurally. See 4.3.	No

The call **audio** already contains the customer's spoken health disclosures and is already retained under the existing service. This feature does not introduce health data into CallGuard for the first time. It moves it from audio, which is not searchable at scale, into readable and searchable text. That distinction is the substance of the added risk.

6. Lawful basis and Article 9 condition

To be confirmed by the controller. CallGuard cannot determine this on the controller's behalf.

The controller must confirm and record:

1. **The Article 6 basis.** Legitimate interests is the likely basis, the interest being prevention of non-disclosure and compliance with FCA obligations, with the customer's interest in cover being paid supporting rather than opposing it. A legitimate interests assessment should be recorded.
 2. **The Article 9 condition** permitting the health processing. Candidates:
 - **Article 9(2)(a), explicit consent.** The customer already gives explicit consent for health data to be used for the application. Whether that consent as currently worded extends to verification of the application by a compliance system is the question, and it may need amending.
 - **Article 9(2)(f)**, establishment or defence of legal claims, which fits the defensive use case where an insurer disputes a disclosure.
 - **DPA 2018 Schedule 1 Part 2 paragraph 20 (insurance) or paragraph 12 (regulatory requirements relating to unlawful acts and dishonesty)**, either requiring an appropriate policy document under Schedule 1 Part 4.
 3. **That the privacy notice covers it.** The most likely gap. A notice drafted for call recording and quality assurance may not cover a processor retaining health answers in readable form for verification. Under 0.2 this applies to **every call**, not only reconciled sales, which widens what the notice must support.
-

7. Necessity and proportionality

QUESTION	ASSESSMENT
Is there a less intrusive way to achieve the purpose?	Yes — the two-tier design in 4.8, which was rejected on cost and complexity rather than on capability. This is the weakest point of the proportionality argument and is stated as such.
Could redaction be kept?	No. Section 3.4 establishes empirically that the purpose cannot be achieved on redacted transcripts, and that redaction is degrading the existing service.
Could manual review achieve the same outcome?	Not at this volume. Manual listening to every call against every question set would expose more staff to the same data for longer with no audit trail. The automated route is less intrusive in practice.
Is the data minimised?	Partly. Only defined questions enter the reconciliation record, the application pack is discarded, and the identity-only profile avoids health entirely where the insurer document contains none. But the transcript necessarily contains the whole call. See R2.
Is retention limited?	Weakened in 0.2. Health now follows the firm's standard retention (5 year default) rather than a separate 12 month clock.
Is access limited?	Not yet. Depends on action 11.
Is the purpose limited?	Yes. Used for discrepancy detection and evidential response to insurer queries. Not used for model training by CallGuard or any sub-processor, and not for secondary analytics.

8. Technical and organisational measures

MEASURE	DETAIL
Encryption at rest	Call audio encrypted with AES-256-GCM. Database storage encrypted at rest.
Encryption in transit	TLS for all external calls including both sub-processors.
Payment data	Excluded by schema constraint plus service-level filter, with unit tests. See 4.3.
Access control	Role based and organisation scoped. Cross-firm access is impossible by construction; every query is organisation scoped. Within a firm, see action 11.
Audit logging	Category changes and enablement written to an append-only log protected by database triggers against update and deletion.
Sub-processor controls	Deepgram: data processing agreement in place; model improvement opt-out enabled, so audio and transcripts are not used to train their models. Anthropic: commercial terms provide that API inputs and outputs are not used for training. Action: confirm and record the current retention position for both.
No model training by CallGuard	CallGuard does not train or fine-tune any model on customer data.
Deletion on termination	All firm data deleted within 30 days of contract termination.
Staff access	CallGuard platform staff access to production is limited to named administrators and is audit logged.
Verification tooling	A script re-transcribes a real call under a proposed category list and reports what would be exposed, so a configuration can be tested before it is applied to a tenant.

9. Risks and mitigations

Likelihood and impact scored low, medium or high. Residual risk is after mitigation.

R1. Health data in readable form is exposed in a breach

Inherent: medium likelihood, high impact. Mitigations: encryption at rest and in transit; organisation scoping; role-based access; no copy in the CRM because flags are not pushed there. **Residual: low likelihood, high impact. Higher than in 0.1**, where the exposed population was one year of reconciled sales. It is now the firm's entire call history for the standard retention period.

R2. The transcript contains far more than the answers required

Inherent: high likelihood, medium impact. Certain to occur. The provider cannot redact selectively, so the transcript contains the whole conversation, including health disclosures outside the question set. Mitigations: the structured reconciliation record extracts only defined questions, so the wider transcript is not surfaced in reports, exports or alerts; the identity-only profile avoids health entirely where the insurer document has none. **Residual: high likelihood, low impact.** A known and unresolved limitation. Revisit if the provider offers selective redaction.

R3. Internal misuse by an authorised user

Inherent: medium likelihood, medium impact. Under 0.2 the everyday transcript view carries health in the clear, so without view gating every user of the firm's account can read any customer's health history, including advisers who previously saw only placeholders.

Mitigations: **the controller has decided that only the admin role may read an unredacted transcript** (*decided 3 August 2026; action 11*). For every other role the transcript is **withheld in full**, and the API does not return it.

Withheld rather than re-redacted, deliberately. Once a transcript is stored with health in the clear, suppressing it again on the way out would mean detecting health content in free text with our own pattern matching. Any term that pattern missed would be shown to a viewer as ordinary conversation, in a view that appeared to be redacted — a worse position than plainly withholding it, because nobody would know to distrust it. There is no safe middle setting here.

The restriction applies only to firms that actually keep a category in the clear. For every other tenant the provider has already redacted at source and nothing changes, so no firm loses access to a transcript that was never sensitive.

Advisers remain restricted to their own calls in any case. This is stricter than the 0.1 design, which allowed supervisors as well. Alongside that: audit logging, and the controller's own staff policies and training.

Residual: low.

Operational consequence the controller should note. Supervisors are the people who normally investigate a breach and coach an adviser, so restricting readable transcripts to administrators means a supervisor working a reconciliation finding sees the flag, the question, the application answer and the evidence quote, but cannot read the surrounding conversation in full. That is a deliberate trade of convenience for exposure, and it can be widened to supervisors later without re-assessing anything else in this document — but doing so returns R3 to its inherent rating and should be recorded as a change.

R4. A discrepancy flag is wrong and an adviser is treated unfairly

Inherent: medium likelihood, medium impact. Flags are produced by software reading a transcript and a document. A false flag is an implied allegation that an adviser mis-recorded a disclosure, which could affect their employment. Mitigations: flags are decision support, **not** automated decisions within Article 22. Every flag carries its evidence: the question, both values, the source call and a link to the point in the recording. Low-confidence extractions route to manual review rather than being flagged. Where the primary detection is a deterministic text search, the reasoning is reproducible and inspectable rather than a model's opinion.

Residual: low likelihood, medium impact. Action: controller to confirm its process for human verification before any action on a flag.

R5. Health data leaks into an export or a notification

Inherent: medium likelihood, medium impact. Exports and email or Slack alerts are routes out of the controlled environment, and email is not an appropriate channel for health data. Mitigations: exports and alert payloads must carry the question, the fact of a discrepancy, and a link back into CallGuard, never the answer content.

Updated in 0.4. That control now exists and is covered by test — **section 4.10**, action 8 closed. Two things the earlier rating did not say, and should have. First, the exposure was wider than the word "export" suggests: the same quote was reaching the firm's CRM, outbound webhooks on two separate code paths, two file downloads and a partner API, and it was a verbatim quote rather than a model's paraphrase. Second, the rating was written as though the control existed; it did not, so between 0.2 and 0.4 the operative residual was the inherent one. Recording that plainly matters more than a tidy table.

One route remains open by design, the claims-defence pack, and it is now stated rather than assumed — see 4.10.

Updated in 0.5. A new destination exists and is deliberately held to this same rule: the unauthenticated adviser confirmation page, which now names findings and carries firm-authored guidance but not the model's reasoning — **section 4.11**, open action 13. It is not an export, but it is reachable without a login, so treating it as one is the safer reading.

Residual: low likelihood, medium impact, for every route except the claims-defence pack, whose export is a controller decision taken per sale.

R6. Data subject rights are harder to satisfy

Inherent: low likelihood, medium impact. Simpler under 0.2 than 0.1, because there is one transcript rather than two. Mitigations: the transcript and reconciliation record are keyed to the same call and customer records that existing subject access and deletion paths use. **Action: confirm subject access export includes the reconciliation record. Residual: low.**

R7. Removing number redaction reopens a bank-detail leak path

Inherent: medium likelihood, high impact. *(New in 0.2; mitigated in 0.3.)* The provider's number-sequence redaction is what actually catches bank details spoken aloud; the per-entity detectors miss them, which was verified against a live call. But that same category redacts the short numeric answers reconciliation depends

on (cigarettes per day, blood pressure readings, weight, units of alcohol), so there is real pressure to switch it off.

Mitigations: CallGuard now operates its own bank-detail redaction, described in 4.9. It runs on every transcript before storage and before either sub-processor sees it, anchors on the spoken phrase so that numeric answers survive, and covers the raw provider payload as well as the readable transcript. It cannot be disabled by configuration. Validated against the first firm's 71 real transcripts: no bank detail survived in 30 reconstructed cases, and none of 424 numeric answers were lost. The provider's payment-data category remains force-enabled beneath it, and the verification script fails a run if a bank-length sequence survives.

The residual exposure is a disclosure with no anchoring phrase anywhere before it. Every disclosure in all 34 real calls examined had one, since the adviser asks before the customer answers, and the raw payload has an unconditional backstop for long digit runs.

Residual: low. The number category is now permissible for a firm with a signed assessment. It remains impermissible for any firm without one, and the control in 4.9 must be confirmed present by the verification script before a firm's configuration is changed.

R8. Scope creep

Inherent: medium likelihood, medium impact. The temptation to enable this broadly, or to treat unredacted transcripts as the new default because they are more useful, is real, and is stronger under 0.2 because there is no longer a separate protected tier to breach. Mitigations: configuration is platform-staff only, requires recorded justification, is audit logged, and is conditional on a signed assessment per firm. Each tenant is a separate controller and cannot be enabled by default. **Residual: low, contingent on that policy being maintained.**

10. Summary of actions before enablement

#	ACTION	OWNER
1	Confirm the Article 6 basis and record a legitimate interests assessment	Controller
2	Confirm the Article 9 condition and put an appropriate policy document in place if relying on a DPA 2018 Schedule 1 Part 2 condition	Controller
3	Review the privacy notice and call script consent wording against all calls , not only reconciled sales	Controller
4	Confirm the process for human verification of a flag before any action affecting an adviser	Controller
5	Decide whether the residual risk in 4.7 and section 11 is acceptable, or whether to revert to the two-tier design of 0.1	Controller + CallGuard
6	Sign this assessment	Controller
7	Confirm and record the current retention position of both sub-processors, and add them to the controller-facing sub-processor list	CallGuard
8	Implement and test the control that exports and alerts carry no answer content (R5) Done, 10 September 2026. Described in 4.10 and covered by test at each exit. Two things the controller should read rather than take on trust: the quote had been leaving ungated until this was built, so what already reached those destinations is a separate question of fact (4.10); and the claims-defence pack still exports it deliberately, which is now stated rather than implied.	CallGuard
8b	Establish, from the delivery records, what call content has already been written to the CRM, to outbound webhooks and to downloaded files for firms keeping a category in the clear — and decide together what, if anything, follows	Controller + CallGuard
9	Confirm subject access export includes the reconciliation record (R6)	CallGuard
10	Do not permit the number category until in-house digit-run redaction is in place and verified (R7) Done, 3 August 2026. The control is described in 4.9 and validated against the firm's real transcripts. Permitting the category for this firm remains conditional on actions 6 and 12.	CallGuard
11	Decide and implement who can read an unredacted transcript within a firm (R3) Done, 3 August 2026: the admin role only , enforced at the API for firms keeping any category in the clear. Transcript content is withheld from every other role rather than partially masked; see R3.	Controller + CallGuard
12	Run the verification script against a real call under the proposed category list and record the output Done, 3 August 2026. A real 20 minute sale re-transcribed with every category permitted; no bank-length digit run survived. Output recorded in 4.9. To be repeated on any change to the category list.	CallGuard

#	ACTION	OWNER
13	Decide whether the model's reasoning may be shown on the unauthenticated adviser page (4.11). Two things follow from it either way, and both are live now: an adviser with no login currently has nowhere to read the detail the email tells them is in CallGuard, and the page has just started naming findings and firm guidance without it. Withheld pending this decision, which is a disclosure judgement rather than a technical one.	Controller
14	Redact document text before it is sent to Claude to learn a new insurer format (4.12) Done, 15 September 2026. Described in 4.12. The gap this closes predates this document — no version of this assessment described the call, so it was never covered by a decision to accept it. Establish, if records allow, whether any real insurer application document reached Anthropic unredacted this way before the fix, and decide together what, if anything, follows.	Controller + CallGuard

11. Conclusion and residual risk

The processing is necessary for a legitimate and, for the customer, protective purpose: ensuring that what a person disclosed when applying for cover is what their insurer was told, so cover is not voided at claim. Section 3.4 establishes that it cannot be achieved on redacted transcripts, and that redaction was already degrading the compliance analysis the controller pays for.

One risk is not fully mitigated and is recorded as a known limitation. **R2**, that the transcript necessarily contains the whole call rather than only the answers required, is a constraint of the transcription provider.

R7, the bank-detail leak path, was the other, and 0.3 closes it. It is no longer controlled by refusing the number category but by a control CallGuard operates directly (4.9), measured against the firm's own calls. Its residual is a disclosure made with no anchoring phrase before it, which did not occur in any of the 34 real calls examined and which the raw-payload backstop and the payment-data category further bound. The controller should still treat action 12, running the verification script against real calls under the proposed category list, as a precondition rather than a formality.

The residual risk under this version remains higher than under 0.1, on one axis. Health data now persists on every call for the firm's full retention period rather than on reconciled sales for twelve months. That was a deliberate trade for a simpler and cheaper system, and it is the controller's to accept or refuse. The two-tier design remains available and is documented in 4.8 as the fallback.

The access axis, however, is now **more** restrictive than 0.1: readable transcripts are limited to the `admin` role, where 0.1 allowed supervisors as well (R3, action 11). The 0.1 comparison in 4.7 should be read with that in mind.

Subject to the actions in section 10 — and in particular to the outstanding implementation of the role restriction, which is a precondition of enablement rather than a follow-up — the residual risk is assessed as **acceptable**, and the benefit to customers of preventing voided policies is judged to outweigh it.

12. Sign off

Names filled in below are pre-printed; blank fields are to be completed by hand.

Prepared by — CallGuard AI

NAME	ROLE OR JOB TITLE	DATE
Kofi Vickery		
SIGNATURE		

Controller approval — Trust Point

NAME	ROLE OR JOB TITLE	DATE
SIGNATURE		

Data protection lead or DPO

NAME	ROLE OR JOB TITLE	DATE
SIGNATURE		

This feature must not be enabled in production until the controller approval above is signed and dated.